

Clase 008 — Windows esencial para seguridad: arquitectura, registro y servicios

Parte: **0 — Fundamentos y prerequisites** · Fuente: *Russinovich, Solomon & Ionescu, Windows Internals*
⌚ Duración estimada: **110 min** · Nivel: **Fundamentos**

Objetivo

Comprender cómo funciona Windows por dentro lo suficiente para atacarlo y defenderlo: su arquitectura, el modelo de seguridad (SID, tokens, UAC), el Registro y los servicios. Windows domina el parque corporativo, así que estos fundamentos son indispensables para el resto del programa.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Describir** la arquitectura de Windows (user mode vs. kernel mode).
2. **Explicar** el modelo de seguridad: SID, tokens de acceso y UAC.
3. **Navegar** y consultar el Registro de Windows con criterio de seguridad.
4. **Gestionar** servicios y detectar los mal configurados.
5. **Identificar** rutas comunes de persistencia y escalada en Windows.

Temas

#	Tema	Por qué importa
1	Arquitectura NT	user/kernel mode, subsistemas
2	SID y cuentas	Identidad y privilegios
3	Tokens y UAC	Cómo se conceden y elevan permisos
4	Registro	Configuración y persistencia
5	Servicios	Procesos privilegiados de fondo
6	Procesos y DLLs	Superficie de inyección y hijacking
7	Logs de eventos	Fuente de detección y forense
8	Persistencia común	Run keys, tareas, servicios

Definiciones y características

- **User mode / Kernel mode:** separación de privilegios de ejecución. Clave: el kernel accede a todo; un fallo ahí compromete el sistema.

- **SID (Security Identifier)**: identificador único de cuentas/grupos. Clave: S-1-5- ... ; S-1-5-32-544 es Administradores.
- **Token de acceso**: estructura que porta la identidad y privilegios de un proceso. Clave: base de la suplantación y el robo de tokens.
- **UAC (User Account Control)**: mecanismo que separa privilegios estándar de los de administrador. Clave: la elevación no es una frontera de seguridad infalible.
- **Registro**: base de datos jerárquica de configuración (HKLM, HKCU...). Clave: Run / RunOnce son persistencia clásica.
- **Servicio**: proceso de fondo gestionado por el SCM, a menudo con privilegios altos (SYSTEM). Clave: rutas sin comillas o permisos débiles = escalada.

Herramientas y preparación

Usa una VM Windows de evaluación en tu laboratorio. Instala **Sysinternals Suite** (Process Explorer, Autoruns, Process Monitor) desde <https://learn.microsoft.com/sysinternals/>. Herramientas nativas: regedit, services.msc, sc.exe, whoami /all, wevtutil, Visor de eventos. Trabaja siempre en la VM aislada.

Laboratorio guiado

1. **Identidad y privilegios**. En una consola:

```
cmd whoami /all
```

Localiza tu SID, grupos y la lista de privilegios (SeDebugPrivilege , etc.). 2. **Explorar procesos** con Process Explorer: observa el árbol, el usuario de cada proceso y las DLLs cargadas de uno. 3. **Registro y persistencia**. Abre regedit y navega a:

```
text HKCU\Software\Microsoft\Windows\CurrentVersion\Run
HKLM\Software\Microsoft\Windows\CurrentVersion\Run
```

Anota qué se ejecuta al iniciar sesión. 4. **Autoruns**. Ejecuta Autoruns y revisa todas las categorías de auto-inicio; identifica entradas no firmadas. 5. **Servicios**. Lista servicios y su binario:

```
cmd sc query state= all | more wmic service get name,pathname,startmode | more
```

Busca rutas con espacios **sin comillas** (vulnerabilidad de *unquoted service path*). 6. **Logs de eventos**. Consulta inicios de sesión (evento 4624/4625):

```
cmd wevtutil qe Security /q:"*[System[(EventID=4625)]]" /c:5 /rd:true /f:text
```

 **Nota ética**: la enumeración de servicios, registro y privilegios se realiza en **tu propia VM** de laboratorio. Aplicar esto a equipos ajenos sin autorización es ilegal.

Ejercicios

1. Explica la diferencia entre HKLM y HKCU y qué implica para persistencia por usuario vs. por máquina.
2. Investiga qué es SeImpersonatePrivilege y por qué es relevante para escalada.
3. Encuentra en tu VM un servicio con "unquoted service path" o razona por qué no hay ninguno.

4. Documenta 3 ubicaciones de persistencia distintas y cómo detectarlas con Autoruns.
5. Compara UAC con `sudo` de Linux: similitudes y diferencias de modelo.
6. Con el Visor de eventos, distingue un login interactivo (tipo 2) de uno de red (tipo 3).

Reto verificable

Realiza una mini auditoría de *hardening* de tu VM Windows: enumera cuentas y privilegios, identifica todas las entradas de auto-inicio con Autoruns marcando las no firmadas, y revisa servicios en busca de rutas sin comillas o binarios en carpetas escribibles. Entrega un informe con hallazgos y recomendaciones.

Criterio de aceptación: el informe lista al menos 5 puntos de auto-inicio clasificados por riesgo, indica si existe algún servicio vulnerable (con evidencia del comando usado) y propone una mitigación por hallazgo. Reproducible por otro alumno en una VM equivalente.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Access is denied" al editar el Registro	Falta elevación. Abre la consola/regedit como administrador.
UAC no pide confirmación al elevar	Nivel de UAC bajo o cuenta ya admin con auto-elevación. Revísalo en configuración.
No ves procesos de otros usuarios	Falta privilegio. Ejecuta Process Explorer elevado.
<code>sc</code> no encuentra el servicio	Nombre corto vs. nombre visible. Usa <code>sc query</code> para el nombre real.
Logs de seguridad vacíos	La auditoría no está habilitada. Configúrala en directiva de auditoría.

Preguntas frecuentes

? ¿UAC es una frontera de seguridad? Microsoft afirma que UAC **no** es un límite de seguridad estricto: existen técnicas de bypass. Es una barrera de conveniencia que reduce ejecución accidental con privilegios.

? ¿Por qué SYSTEM es tan codiciado? Es la cuenta de mayor privilegio local, por encima incluso del administrador para ciertas operaciones. Muchos servicios corren como SYSTEM, de ahí que sus fallos permitan escalada total.

? ¿El Registro sustituye a los archivos de configuración? En gran medida sí para Windows: centraliza configuración de SO y apps. Por eso es un objetivo tanto de persistencia como de análisis forense.

? ¿Necesito programar en Windows para esto? No aquí; en la Clase 009 usaremos PowerShell. Ahora basta con entender la arquitectura y saber enumerar con herramientas.

Referencias

- Russinovich, Solomon & Ionescu, *Windows Internals* (Microsoft Press).
- Microsoft Sysinternals — <https://learn.microsoft.com/sysinternals/>
- Windows Registry reference — <https://learn.microsoft.com/windows/win32/sysinfo/registry>

- MITRE ATT&CK, técnica T1547 (Boot or Logon Autostart) — <https://attack.mitre.org/techniques/T1547/>

Siguiente clase

Clase 009 - PowerShell para seguridad ofensiva y defensiva